



南京邮电大学

Nanjing University Of Posts And Telecommunications

银狐家族木马分析及拓展开发实现

张晗洁

厚德弘毅 求是笃行



南京邮电大学
Nanjing University of Posts and Telecommunications

目录

01 研究背景和意义
Research Background and Significance

02 银狐家族木马的分析
Analysis of the SilverFox Family Trojan

03 主要功能及测试
main Features and Testing

04 总结与展望
Summary and Future Work

厚德弘毅 求是笃行



PART 01

研究背景和意义

Research Background and Significance

厚德弘毅 求是笃行



研究背景

- 互联网用户数量庞大，网络安全威胁日益严峻。
- 病毒威胁中，木马病毒占比高。
- 银狐家族木马具有隐蔽性强、传播速度快、危害性大的特点，且近年来不断升级。



研究意义

- 理论意义
丰富恶意代码分析理论，深化对其工作机制的理解。
- 实际意义
增强防范意识，提升网络安全防护能力。



PART 02

银狐家族木马的分析

Analysis of the SilverFox Family Trojan

厚德弘毅 求是笃行

银狐家族木马概述

- 定义：银狐家族木马是高级持续性威胁的典型代表，具有模块化设计和动态通信机制。
- 特点：
 - 高隐蔽性：利用白加黑技术、内存注入等手段。
 - 强适应性：通过模块化设计和动态加载机制实现持久化控制。

演变过程：

版本号	传播途径	文件类型	技术特征
V1.1	伪造网站、伪装程序	可执行文件	多次打包技术、白加黑技术
V1.2	即时通讯工具、钓鱼邮件	可执行文件	独立释放工具、白加黑技术
V1.3	即时通讯工具、钓鱼邮件	可执行文件	外链访问、文件共享服务利用
V2.1	即时通讯工具、钓鱼邮件	CHM/VBM 文件	内存执行、CHM 内嵌脚本
V2.2	即时通讯工具、钓鱼邮件	VBE 文件	IE 浏览器设置修改
V2.3	即时通讯工具、钓鱼邮件	VBE 文件	CHM 模拟更新策略

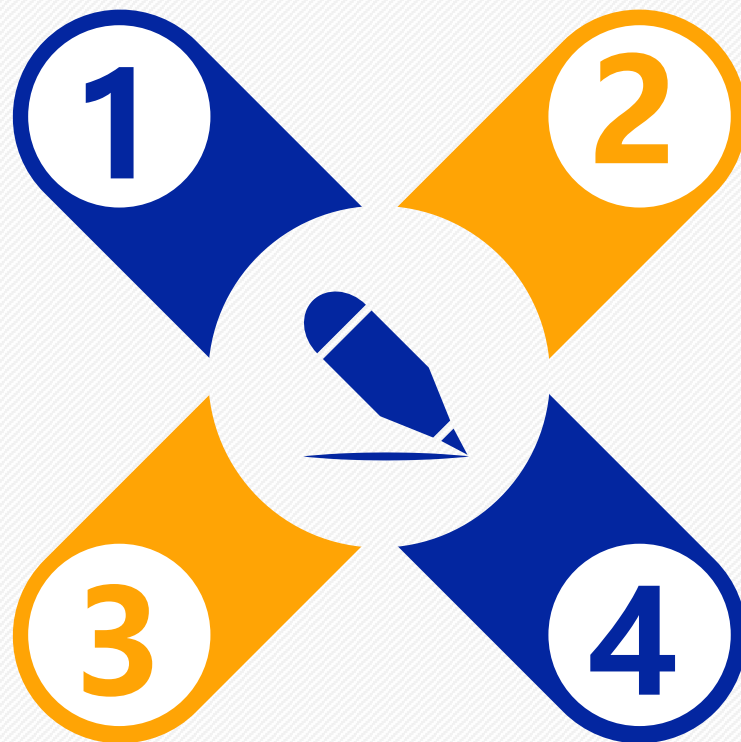
银狐家族木马的传播方式

定向财务政企钓鱼邮件

利用伪装成可信实体的邮件诱导用户点击附件。

软件挂马

利用水坑攻击和广告劫持传播木马。



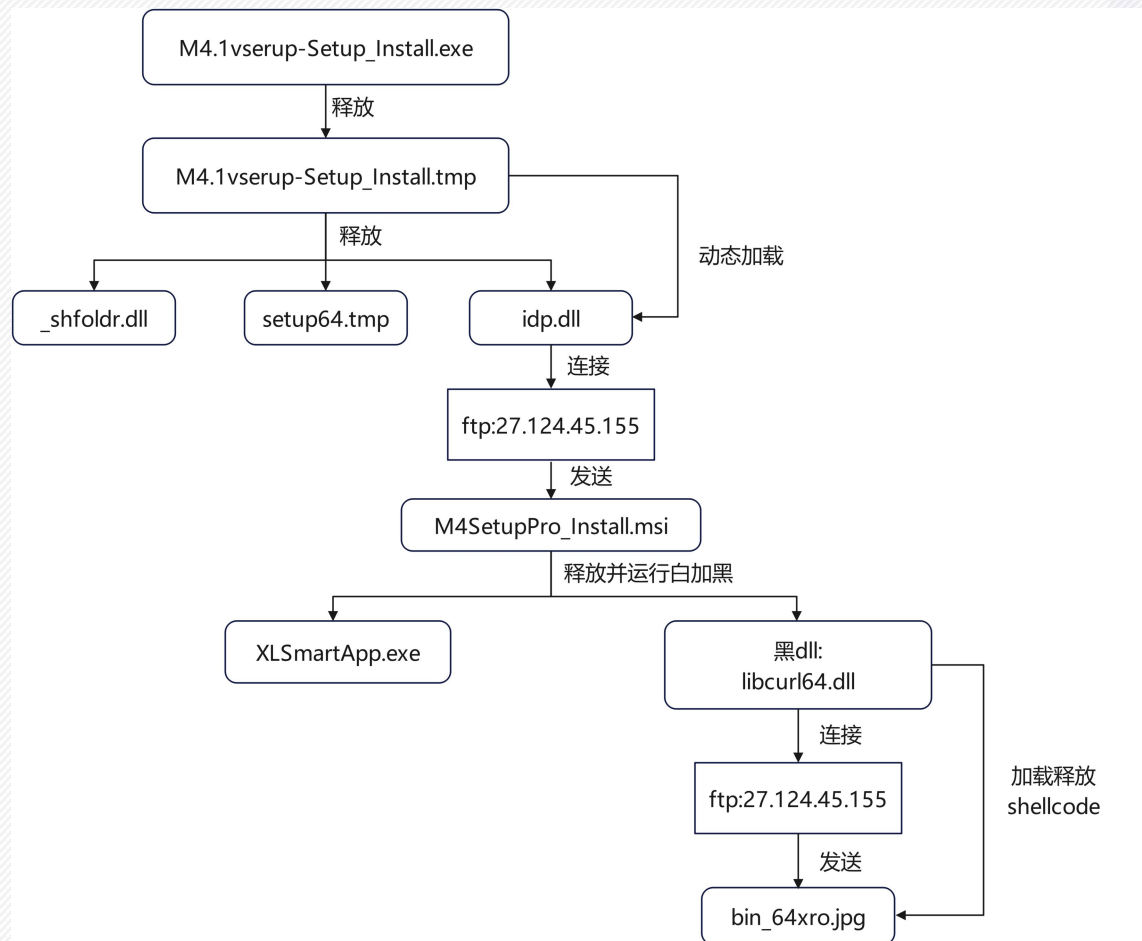
伪造应用下载软件

创建高仿应用下载页面，诱导用户下载恶意程序。

社交信息传播

利用社交软件的联系人关系链快速传播。

恶意负载释放机制



1. 初始载荷释放: `M4.1vserup-Setup_Install.exe`运行后, 在系统临时目录释放执行体。
2. 二级模块部署: 释放辅助功能模块、配置文件和核心FTP下载模块。
3. C2通道建立: 利用FTP凭证下载恶意安装包。
4. 白加黑攻击: 释放带有合法数字签名的程序作为载体, 加载恶意DLL。
5. 内存注入与控制: 将恶意Shellcode注入系统进程, 建立持久化控制通道。

1、白加黑技术

利用合法程序加载恶意DLL，绕过安全检测。

2、内存注入

恶意代码通过API调用在目标进程的内存空间中分配内存并写入恶意代码。通过创建远程线程执行注入的代码，实现恶意功能，同时避免在磁盘上留下痕迹。

3、FTP隐蔽通信

利用FTP服务器进行数据传输和命令控制，从而隐藏恶意行为，避免被网络监控系统检测。

4、模拟鼠标点击

通过模拟鼠标事件生成看似正常的用户交互行为，触发合法程序的功能，从而加载恶意代码。

5、伪造父进程

修改进程的父进程ID，将木马进程伪装成系统或合法应用程序的子进程。

6、利用COM组件

通过修改注册表项，将恶意代码与合法的COM组件关联。当系统调用该COM组件时，恶意代码被加载并执行，利用COM架构的复杂性和动态加载特性来隐藏恶意行为。



PART 03

主要功能及测试

main Features and Testing

厚德弘毅 求是笃行

开发环境

宿主机: Windows 11 专业版, Intel Core i5-11300H

虚拟机: VMware Workstation 17 Pro, Windows 10 专业版

开发工具: Visual Studio 2022 (社区版)

网络配置: NAT + 仅主机模式, 禁止访问外网, 仅允许宿主机与虚拟机间通信

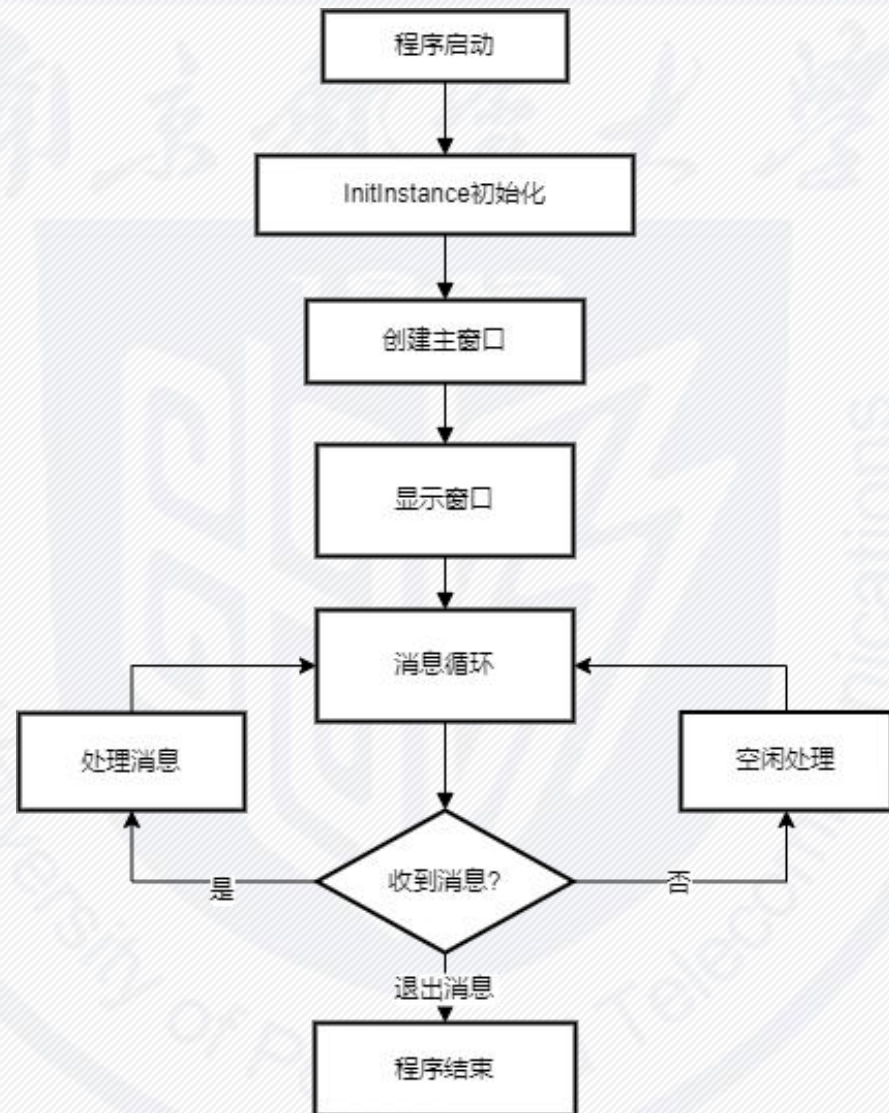
系统架构

框架: 基于MFC框架构建

设计思想: 模块化设计, 分层架构

核心功能: 屏幕监控、文件管理、远程对话、键盘记录、查注册表

厚德弘毅 求是笃行



MFC工作流程图



差异屏幕

1、初始化阶段

建立网络连接，初始化位图缓冲区

创建设备上下文和内存

设置屏幕参数和缩放比例

2、数据接收处理

首次传输：接收完整屏幕数据，zlib解压缩

增量传输：接收差异数据，仅更新变化区域

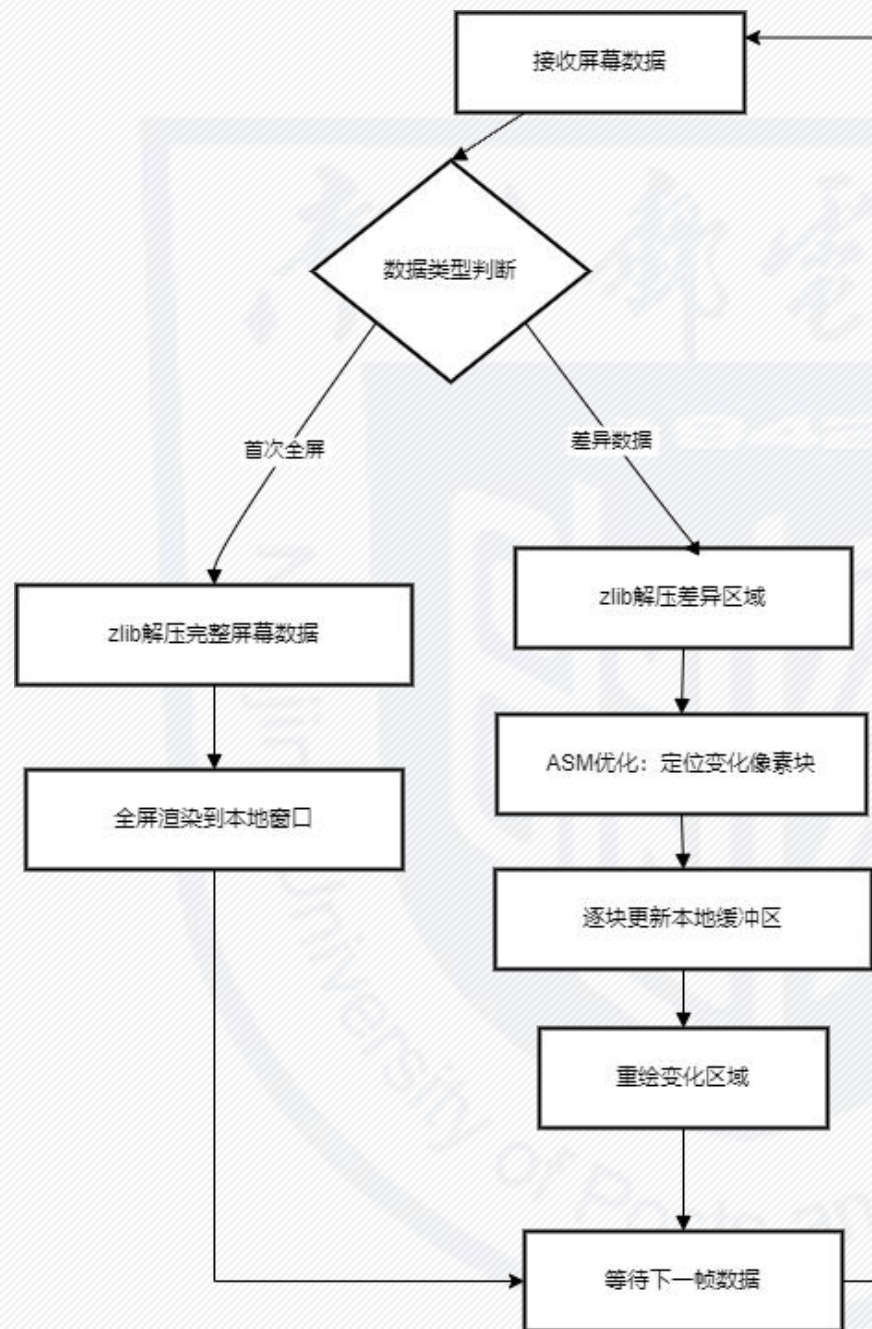
3、高效渲染

差异区域精确定位和更新

4、交互控制

鼠标键盘事件捕获和坐标转换

实时转发用户操作到远程端

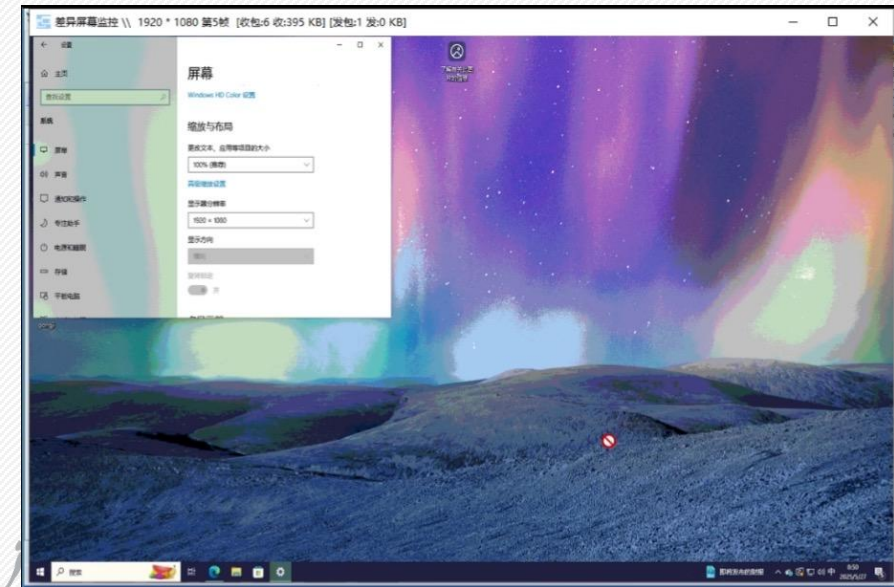
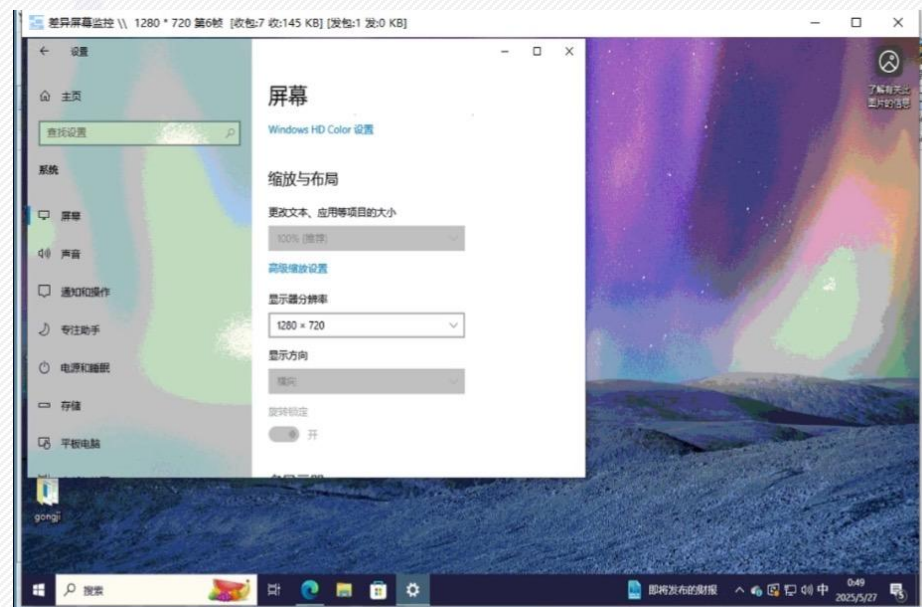
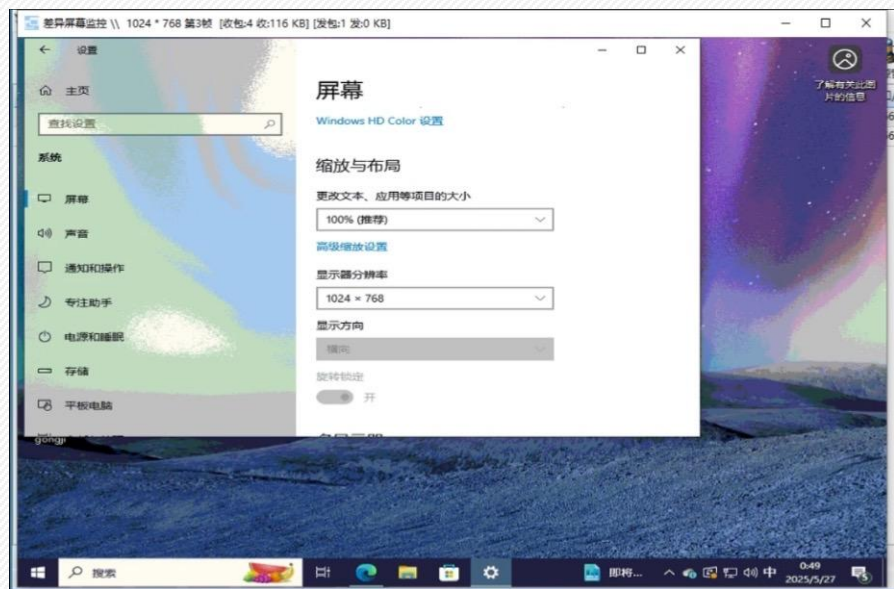


高速屏幕和后台屏幕

特性	差异屏幕	高速屏幕	后台屏幕
核心定位	低宽带远程显示	高画质远程显示	隐蔽监控
数据传输	zlib	JPEG+zlib	JPEG+zlib
隐蔽性	普通模式	普通模式	后台模式
适用场景	对响应速度要求高的场景	观看视频、图片等复杂图像内容	无感知的屏幕活动记录

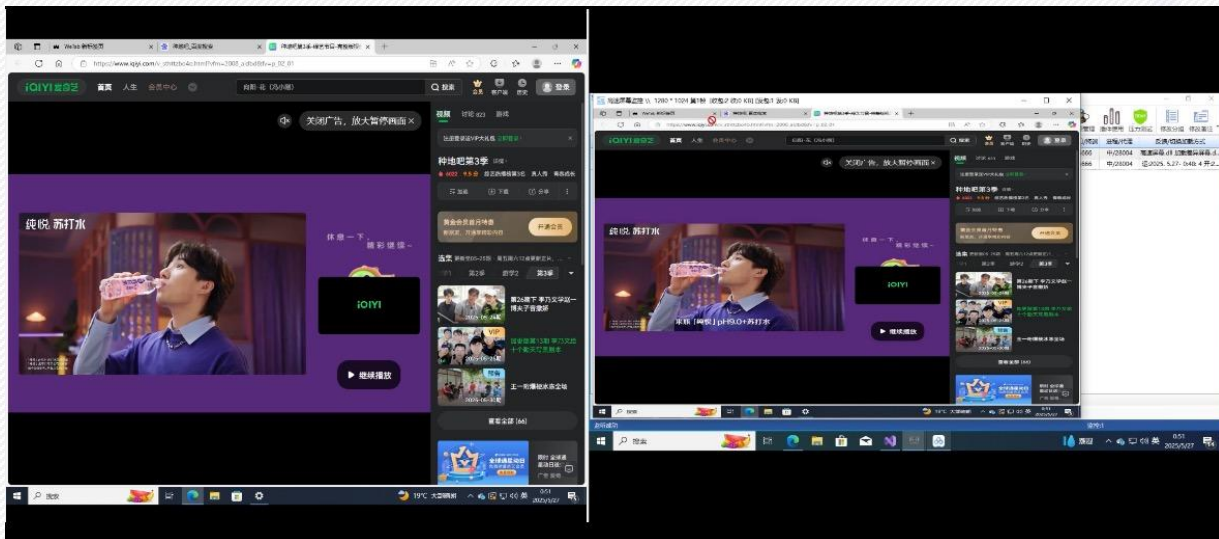
高速屏幕和后台屏幕的运行方式与差异屏幕类似，为了降低宽带传输压力，在zlib压缩后，高速屏幕引入了JPEG压缩技术，将屏幕变化区域编码成多个小的JPEG块，客户端收到后逐一解码这些JPEG块，通过StretchDIBits函数精确更新到屏幕对应区域，更适合观看视频、图片等复杂图像内容。后台屏幕本质上采用了高速屏幕的JPEG压缩方案，但做了关键简化：完全移除了鼠标跟踪功能，这样既保持了JPEG的压缩优势，又降低了处理复杂度，更适合后台监控这种无需交互反馈的场景。

屏幕监控测试



多次切换显示器分辨率，可以看到在不同分辨率下的差异屏幕清晰度显示有所差异。

屏幕监控测试



在被攻击方显示器播放视频，启动攻击方高速屏幕监控，可以发现监控画面并未出现卡顿、拖影现象，图片清晰。



启动后台屏幕监控，能够顺利监控获取画面且不被察觉。

远程文件管理器采用客户端-服务器架构，通过IOCP高性能网络通信。核心流程：用户操作→发送命令→服务器执行→界面刷新。支持新建、删除、重命名、压缩四大功能，每个操作都遵循“输入确认→网络传输→远程执行”的统一模式，实现高效的远程文件管理。

- 新建文件夹

输入对话框获取名称，调用Windows CreateDirectory API，使用创建文件夹网络命令传输路径字符串到服务器执行创建操作。

- 删除文件

利用DeleteFile和RemoveDirectory系统API，支持递归目录删除。通过任务队列批量处理，使用删除命令传输文件路径。

- 重命名文件

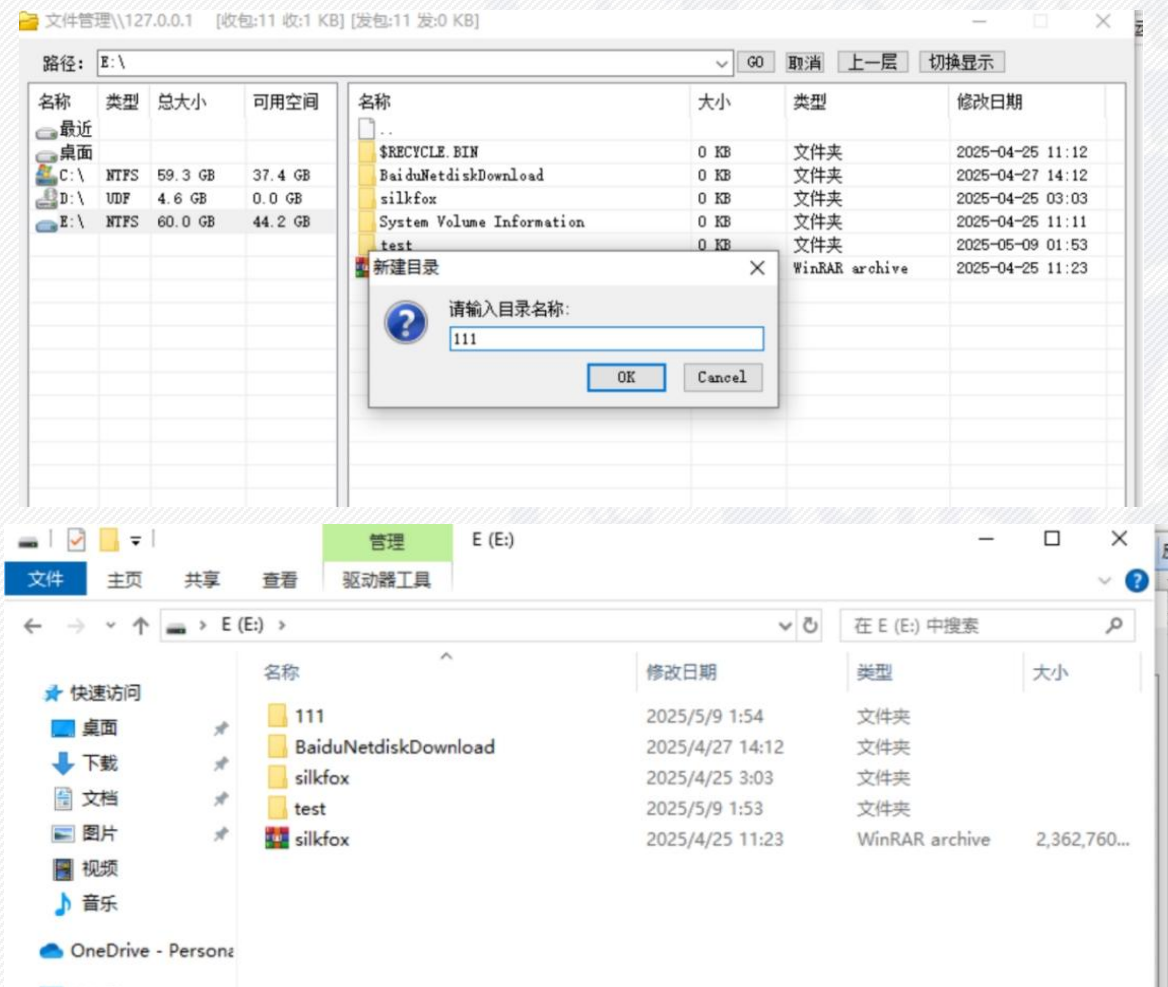
启用列表视图控件的就地编辑功能，获取新旧文件名后调用MoveFile系统API，通过重命名文件命令同时传输原路径和新路径到服务器。

- 文件压缩

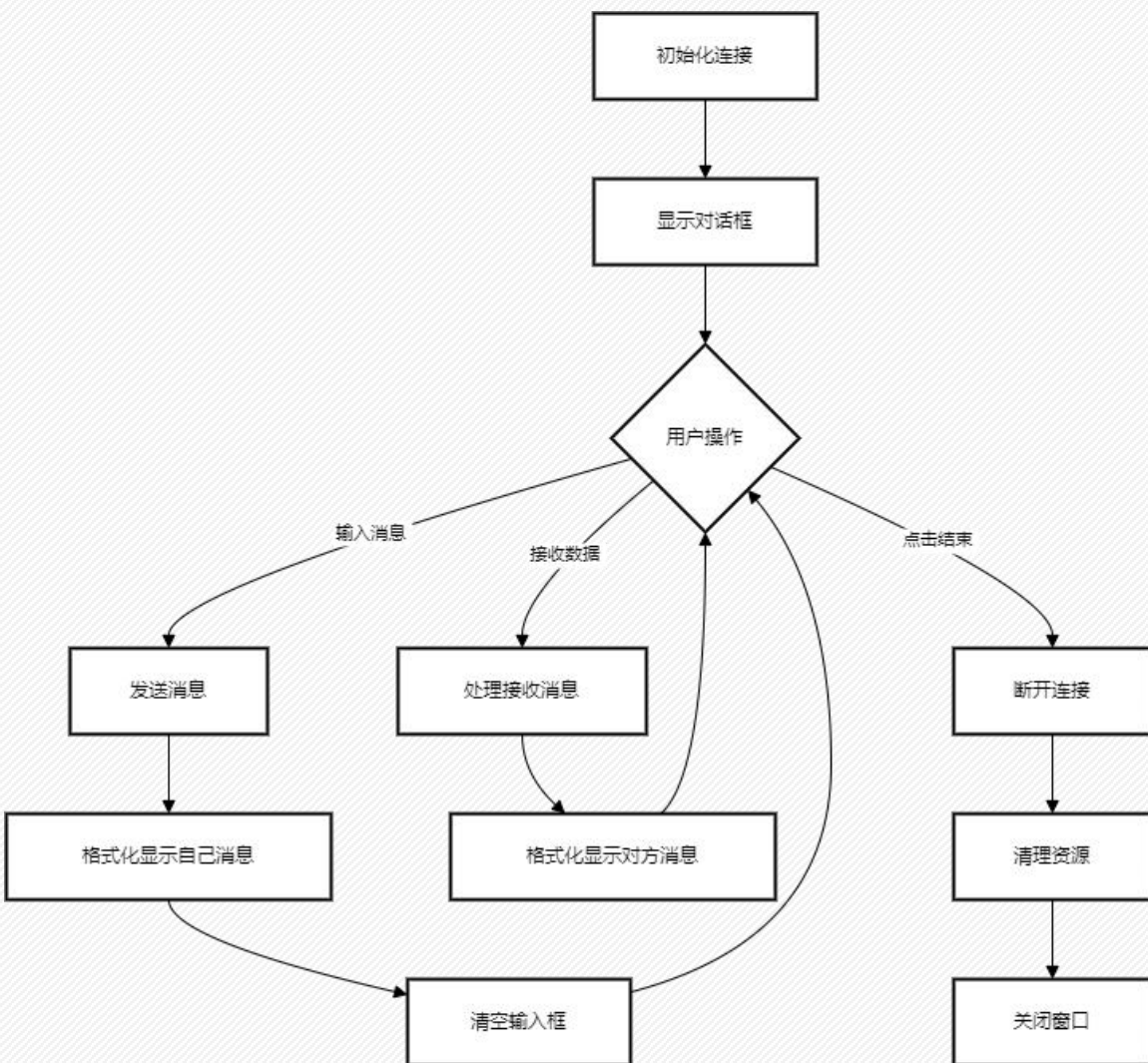
集成WinRAR命令行工具，构造"a -ep1 -ibck -r"等压缩参数，通过CreateProcess系统调用执行WinRAR.exe，使用压缩命令传输压缩参数字符串到服务器。

文件管理功能测试

以新建文件夹功能为例，在攻击方选择新建目录，则能够在被攻击方找到此新建的文件夹。



远程对话功能



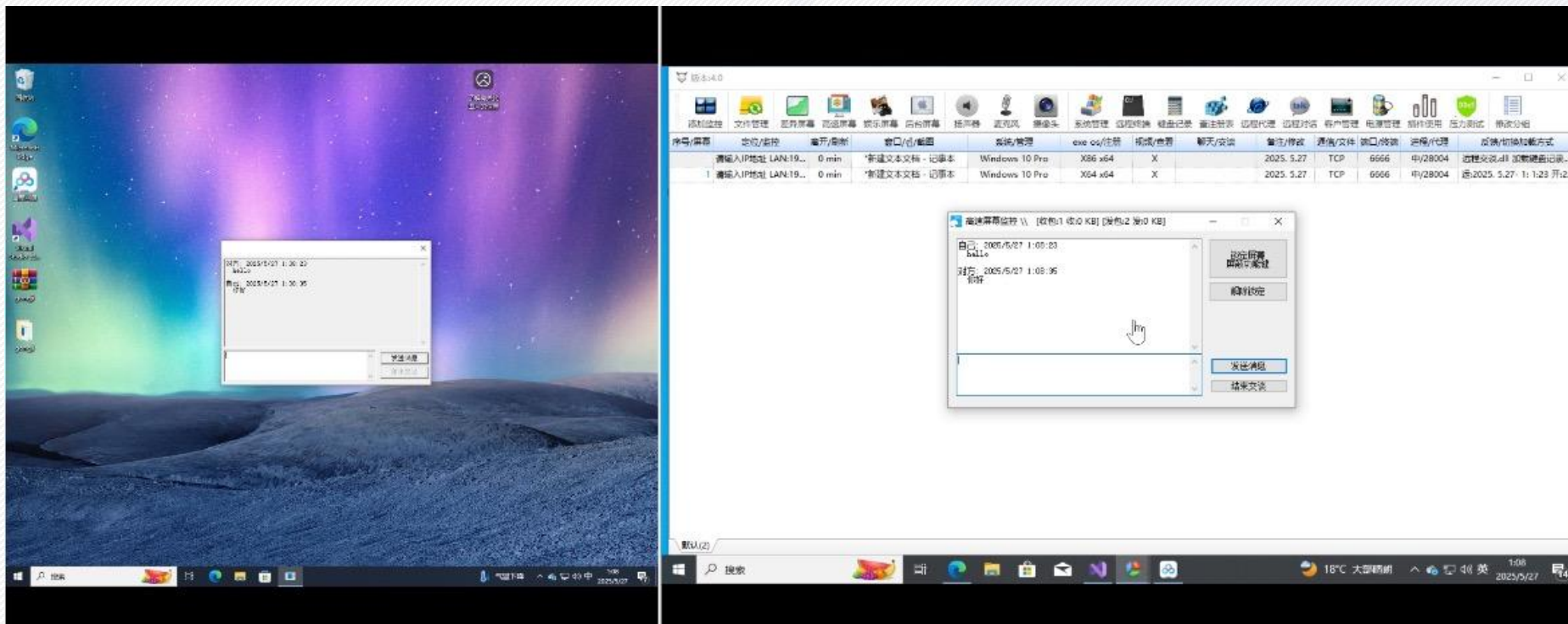
系统启动时首先进行初始化连接，然后显示对话框界面，接着进入核心的用户操作循环。

在这个循环中，系统同时处理两种主要操作：当用户输入消息时，系统会发送消息到远程端，格式化显示用户自己的消息内容，然后清空输入框准备下一次输入；与此同时，系统也在持续监听来自远程端的数据，一旦接收到消息就立即处理并格式化显示对方的消息内容。

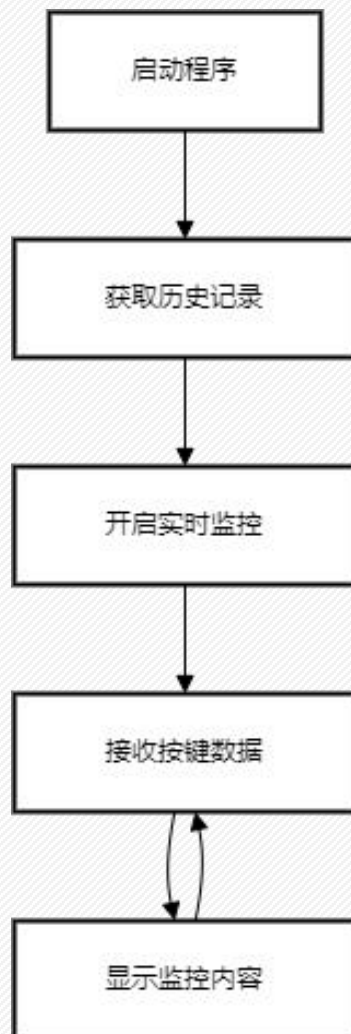
当用户选择结束对话时，系统会执行安全的退出流程，先断开网络连接，然后清理所有分配的资源，最后关闭窗口。这种设计确保了系统在任何情况下都能正确释放资源，避免内存泄漏或连接残留的问题。

远程对话测试

远程对话功能中，攻击方可主动向被攻击方发送信息弹窗，此后双方可以实时发送和接收信息。



键盘记录功能和测试

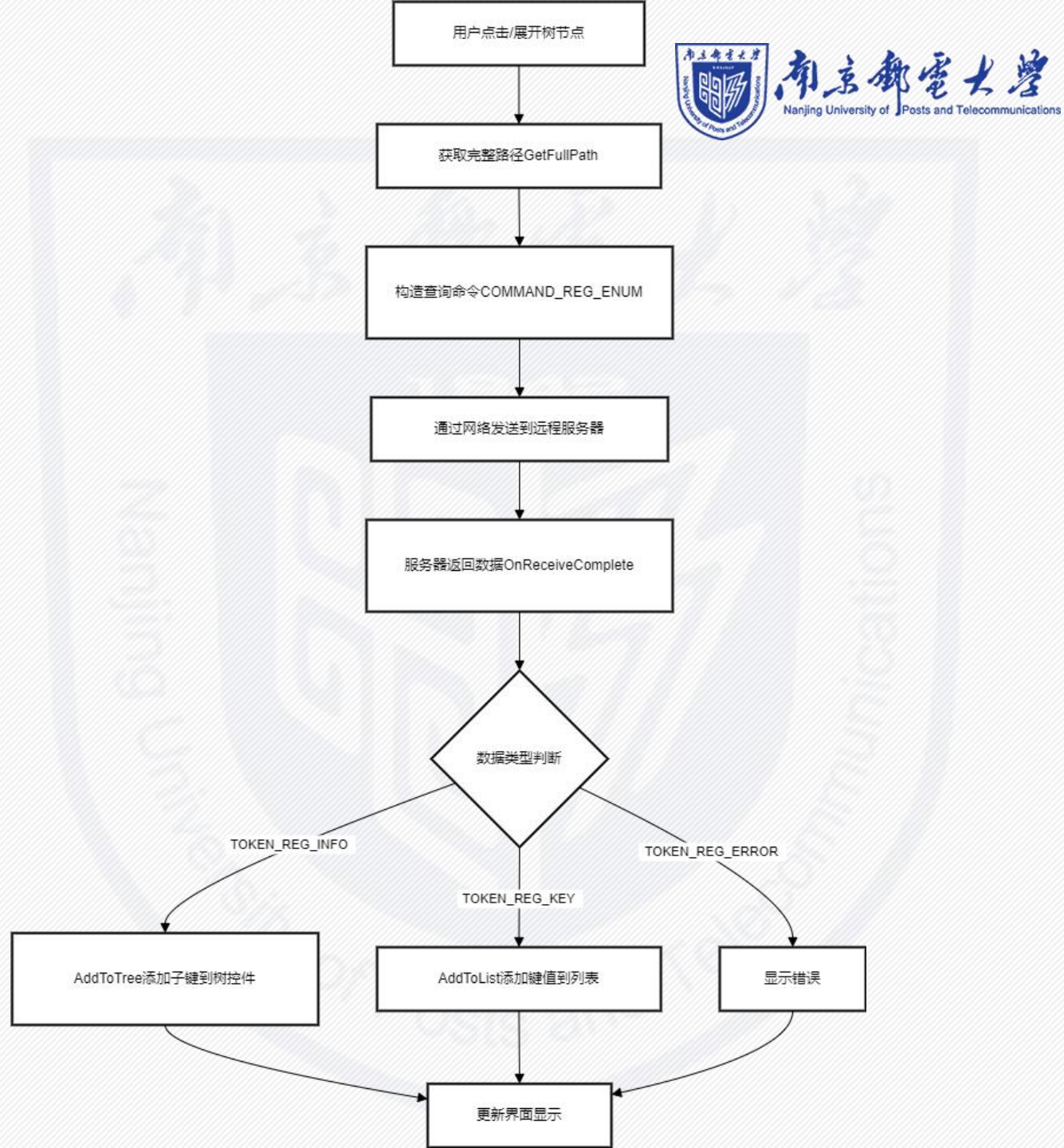


键盘记录功能中程序启动时自动获取被控端的历史键盘记录，然后用户可开启实时键盘监控，实时显示被控端的按键输入，还可备份键盘记录到本地文件。

图中，系统成功捕获了被控端的键盘输入操作，同时记录了键盘的操作时间以及特殊的按键组合。

查注册表功能

在查注册表功能中，当用户点击树形控件节点时，系统通过获取完整路径函数构建完整注册表路径，然后添加注册表查询命令并发送到远程服务器。服务器返回数据后，数据接收处理函数根据数据类型标识进行分发处理：如果是注册表信息类型就将子键添加到树控件，如果是注册表键值类型就将键值对显示在列表中。



查注册表测试

查注册表功能测试中，系统成功读取并展示了目标系统的注册表信息。





PART 04

总结与展望

Summary and Future Work

厚德弘毅 求是笃行



成果

- 成功分析了银狐家族木马的核心技术。
- 实现了木马控制系统的仿生开发。



局限性

- 对最新变种的分析尚未完全覆盖。
- 防御对抗模块还不够完善。



未来展望

- 人工智能与恶意代码分析的融合。
- 无文件攻击防御技术。
- 主动防御体系构建。
- 跨平台攻击研究。



南京邮电大学

Nanjing University Of Posts And Telecommunications

汇报结束 感谢聆听！

General PowerPoint Template Of Work report Or Scientific Report Or Work Plans

厚德弘毅 求是笃行